Authenticator Management Procedure (HPMG, practice document)

Nov 5, 2026 · @Musah

This procedure sets how HPMG issues, protects, changes and recovers passwords and other authenticators on DC01 and the ad.northstar.test domain. HPMG and every person named are fictional, and the document exists only for assessment practice. It was written on 2026-11-05, after the DC01 assessment, as remediation for POAM-008 (IA-5).

1. Document control

Item	Value
Document ID	HPMG-PRO-IA-001
Version	1.0
Owner (designated official)	Information Security Officer (ISO)
Approved by	Chief Executive Officer (CEO)
Effective date	2026-11-05
Next scheduled review	2027-11-05
Related documents	HPMG-POL-AC-001 Access Control Policy; HPMG-POL-AU-001 Audit and Accountability Policy

2. Scope and roles

This procedure applies to every account on DC01 and the domain, including standard accounts, named administrator accounts and service accounts. The ISO owns the procedure and reviews it every 12 months. The System Owner (Director of IT) makes sure the settings in Section 3 stay applied. System Administrators issue and reset passwords. All users protect their own authenticators and report loss at once.

3. Requirements

Requirement	Value
Minimum password length	14 characters
Complexity	Required
Password history	24 passwords remembered
Maximum password age (change period)	42 days for all password types, and immediately on suspected compromise
Account lockout	5 invalid attempts, 15 minutes (see HPMG-POL-AC-001)
Default and vendor passwords	Changed before first use, and never reused
Shared or group accounts	Prohibited unless the ISO approves a written exception

A password may not contain the user's name or account name.

4. Procedures

4.1 Verify identity before issuing an authenticator

1. The service desk confirms the person's identity before issuing or resetting any authenticator. In person, this means a photo ID. By phone or chat, the desk calls back on the number in the HR record, or the person's manager confirms the request in writing.
2. The administrator records who verified the person, how, and when on the ticket.

4.2 Initial authenticators

1. The administrator creates a unique temporary password of at least 14 characters for each account. The same temporary password is never used twice.
2. The administrator sets the account to require a password change at first logon.
3. The temporary password is sent through a different channel than the user name.
4. Accounts created from the approved request are recorded in the account register (HPMG-POL-AC-001, section 9.2).

4.3 Lost, stolen or compromised authenticators

1. The user reports the loss or suspected compromise to the service desk and the ISO right away.
2. The service desk verifies identity as in 4.1, then resets the password with a new temporary password and a forced change at first logon.
3. The administrator disables the account at once if the compromise is suspected to be active, and opens a security incident.
4. The ISO reviews the Security log for the account for the previous 30 days, and records the result on the ticket.

4.4 Changing and refreshing authenticators

1. Passwords expire after 42 days. The domain enforces this, so users are prompted to change.
2. Administrators change a password immediately after a suspected compromise, when a person with knowledge of it leaves, or when a default is found in use.
3. No password is given a "never expires" setting unless the ISO approves a written exception that names a compensating control.

4.5 Protecting authenticators

1. Users never share passwords, write them where others can see them, or send them by email or chat. They store them only in the HPMG-approved password manager.
2. Administrators use their named administrator account only for privileged tasks, and a separate standard account for everything else.
3. Passwords are stored by the system only as hashes. No process writes passwords in plain text to logs, scripts or tickets.
4. Service accounts get long random passwords stored in the approved secrets store, and each is owned by a named person.

4.6 Group and role accounts

Group or role accounts are not used. If the ISO approves an exception, the password is changed whenever anyone leaves the group or the role changes, and the change is recorded on the exception.

5. Records, review and approval

The ISO keeps tickets, identity verification records and review notes for at least six years, in line with HIPAA documentation requirements. The ISO reviews this procedure every 12 months and after any incident involving a compromised authenticator, a major change to DC01, or an assessment finding.

Revision history

Version	Date	Author	Summary
1.0	2026-11-05	Information Security Officer	Initial release. Remediation for POAM-008 (IA-5).

Approval

Role	Name	Date approved
Information Security Officer	Daniel Okafor (fictional)	2026-11-05
Chief Executive Officer	Margaret Ellison (fictional)	2026-11-05

Approval recorded 2026-11-05, after the DC01 assessment. The approvers are fictional people in a fictional organization. This procedure was not in place during the assessment.